INTERNATIONAL UNIVERSITY

FUNDAMENTAL CONCEPTS OF DATA SECURITY

Lecture 1: Data Security Landscape and Incidents

— Foundations & Failures

Dr. Le Hai Duong

lhduong@hcmiu.edu.vn

Learning Objectives

Understand data security scope

Distinguish between data protection and system exploitation

Recognize real data security failures

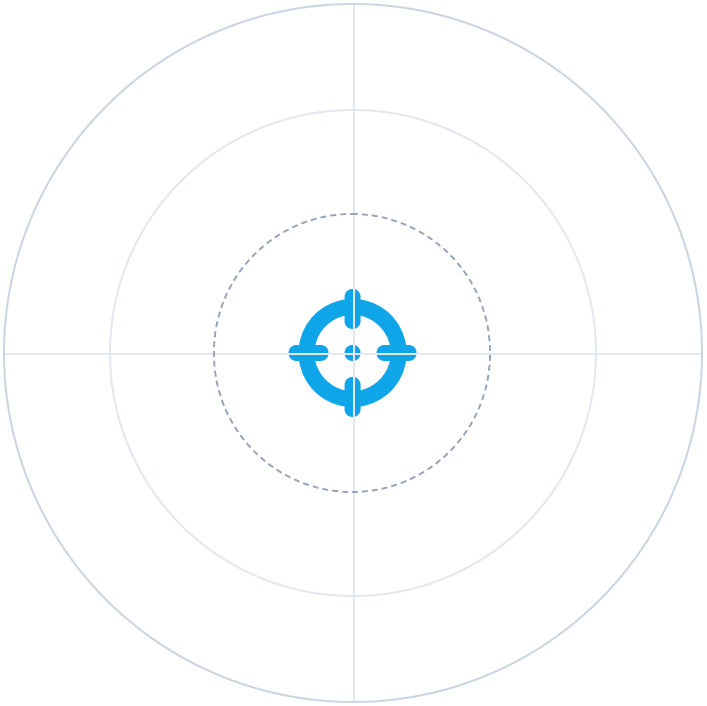
Analyze high-profile breaches and their impacts

Identify recurring weaknesses

Spot patterns like misconfiguration and poor access control

Prepare for security mechanisms

Build the foundation for encryption and hashing topics



CORE DEFINITION

What Is Data?

- **Raw facts and records** representing events, objects, or concepts.
- Exists in both **digital** (bits/bytes) and **physical** (paper/hardware) forms.

DATA LIFECYCLE STATES

Stored
DATA AT REST

→

Transmitted
DATA IN TRANSIT

→

Processed
DATA IN USE

CORE DEFINITION

What Is Information?

- **Processed data** that has been structured, interpreted, or organized.
- Provides **contextual meaning** that is relevant to the recipient.
- Holds intrinsic **business and personal value**, making it the primary target for protection.

INFORMATION TRANSFORMATION FLOW

Information Assets

DATA OBJECTS

The raw facts, records, and intellectual property being protected. Includes PII, financial records, and proprietary secrets.

STORAGE SYSTEMS

Repositories where data rests. Includes databases (SQL/NoSQL), file servers, cloud buckets, and physical backups.

TRANSMISSION CHANNELS

Pathways for data in motion. Includes internal networks (LAN), the public internet, VPNs, and wireless signals.

USERS & PROCESSES

The actors accessing data. Includes employees, customers, third-party APIs, and automated system scripts.

METADATA

Data describing other data. Includes logs, access timestamps, file headers, and classification tags often overlooked in security.

What Is Data Security?

Protection throughout lifecycle

Safeguards data from creation and storage to usage and destruction

Prevents unauthorized access

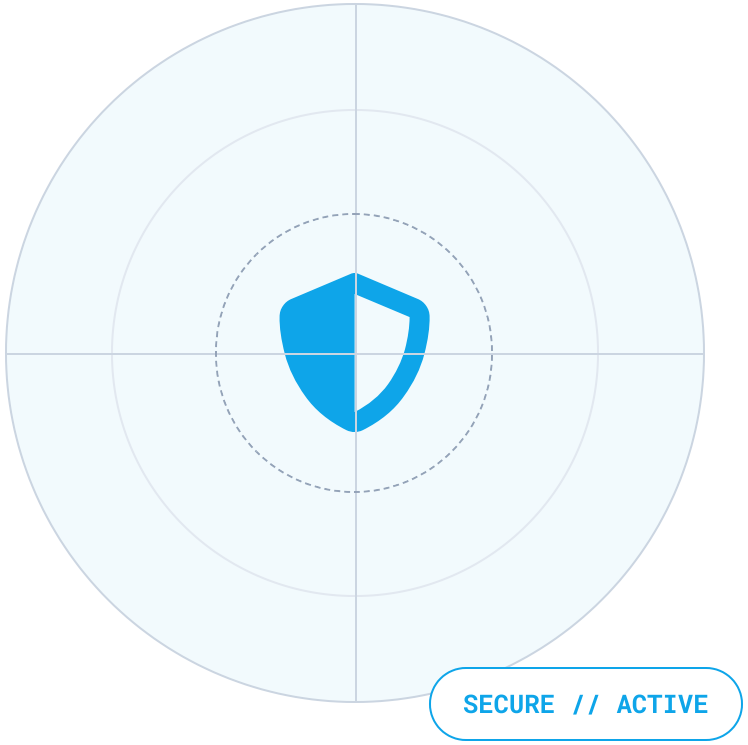
Ensures only approved entities can view, modify, or delete information

Applies to storage, transit, & access

Comprehensive security for data at rest, in motion, and in use

Broader than encryption

Includes governance policies, administrative controls, and physical security



Why Data Security Matters

Large-scale data breaches

Massive incidents motivate strict security requirements

Legal and financial impact

Non-compliance leads to heavy fines and lawsuits

Long-term trust loss

Reputational damage often exceeds direct financial costs

Modern Data Security Landscape

Centralized databases

Aggregated high-value targets in enterprise data centers

Cloud storage

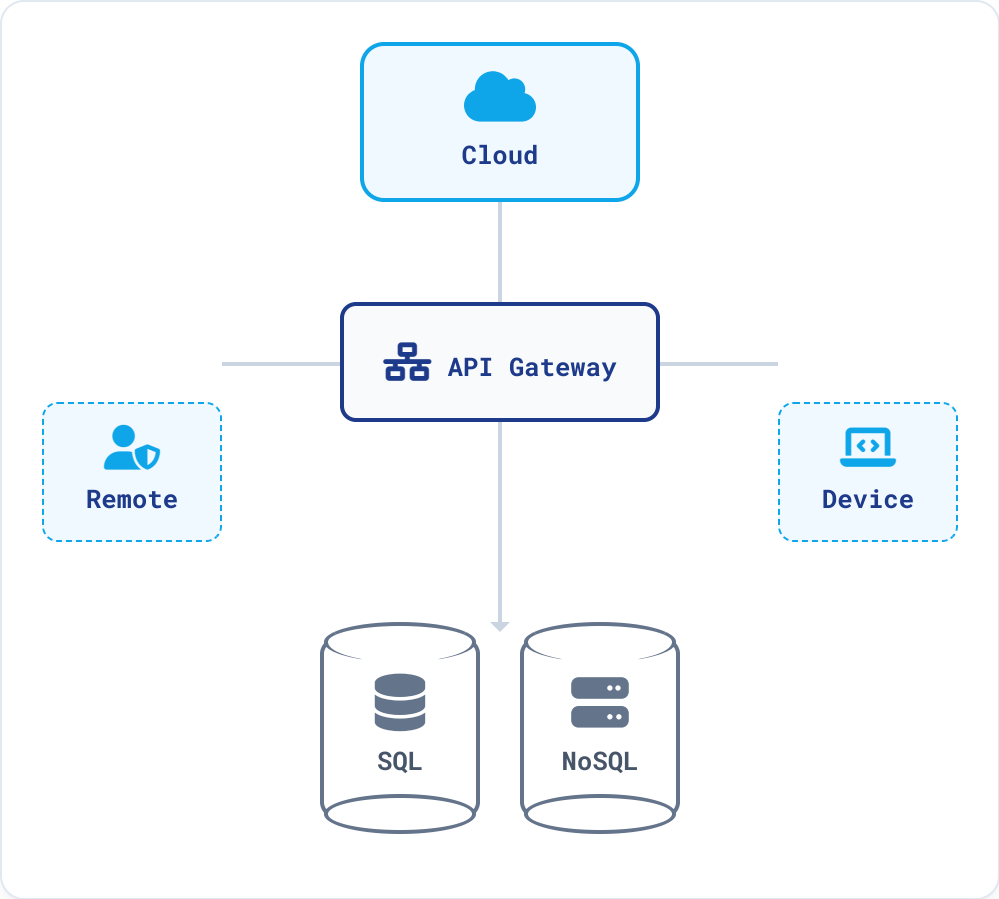
Scalable infrastructure with complex shared responsibility models

APIs and data sharing

Programmable access points that increase the attack surface

Remote access

Distributed workforce expands the traditional security perimeter



Metadata Leakage Case Study

LEC 01 // CASE STUDY

REALITY WINNER // NSA LEAK (2017)

INCIDENT OVERVIEW

NSA contractor leaked a classified report on Russian election interference to *The Intercept*. The news outlet published scans of the printed document without sanitization.

THE METADATA LEAK

The scanned images contained **yellow printer tracking dots** (Machine Identification Code). This invisible steganography encoded the printer's serial number and the exact time of printing.

IMPACT & RESULT

The FBI decoded the dots, identified the specific printer, and cross-referenced logs to find who printed the document at that time. Reality Winner was arrested within days.

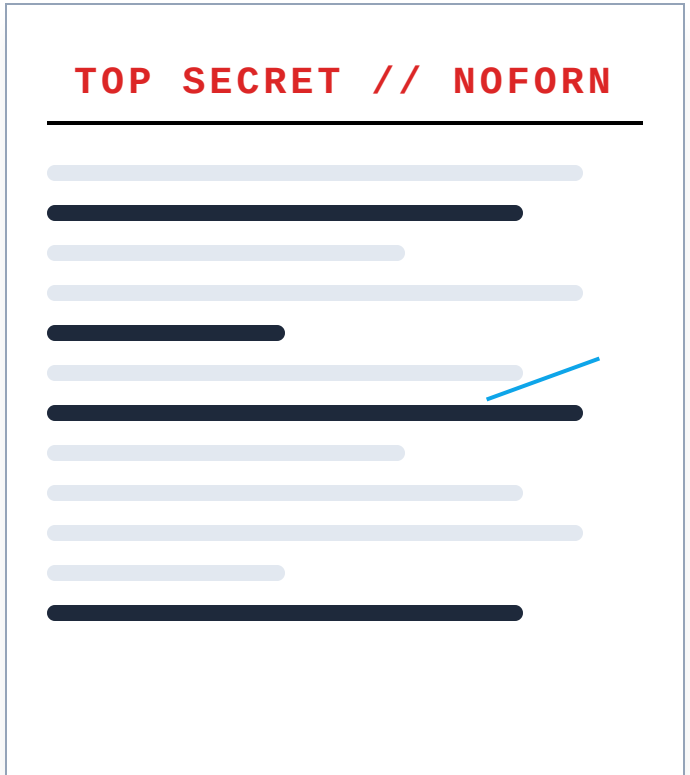
METADATA EXPOSURE

DECODED METADATA

S/N: 535218

Date: 2017-05-09

Time: 06:20



Metadata Leakage Vectors

COMPARATIVE ANALYSIS & VISUAL EVIDENCE

VECTOR TYPE	METADATA EXPOSED	REAL-WORLD RISK EXAMPLE	MITIGATION STRATEGY
EXIF Data	GPS (Lat/Long) Timestamp Device Model	John McAfee's location revealed via photo **GPS data** posted by journalist.	**Sanitize** Use tools like ExifTool to strip data.
Doc Props	Author / Org Edit History File Paths	UK "Dodgy Dossier" plagiarized content revealed via **revision history**.	**Inspect** Use "Inspect Document" to remove PII.
Headers	Origin IP Server Route Client Agent	Attackers map internal network topology via **header routing**.	**Strip** Gateway config to remove internal IPs.

VISUAL DEMONSTRATION: HOW METADATA APPEARS IN TOOLS

Image Inspector - IMG_4092.JPG

Make: Apple iPhone 13
Date: 2023:10:24 14:32:01
GPS: **37 deg 47' 12.4" N**
122 deg 24' 18.2" W

Project_Final.docx Properties

General | **Summary** | Statistics

Title: Q3 Financial Report
Author: Intern_David_Smith
Company: External_Audit_LLC
Saved by: Admin_Root
Rev #: 14 (Total Edit: 420 min)

Source View - Message Header

```
Return-Path: <ceo@partner-corp.com>
Received: from mail.internal.local ([10.0.1.45])
by exchange.gateway (8.14.4) with ESMTP
Date: Tue, 24 Oct 2023 09:15:22 -0500
X-Mailer: Outlook 16.0 (Windows NT 10.0)
X-Originating-IP: [192.168.1.120]
Subject: CONFIDENTIAL: Wire Transfer Specs
```

DATA MISUSE & GOVERNANCE

FACEBOOK 2018

Massive unauthorized harvesting of user profiles by Cambridge Analytica for political targeting, exposing systemic governance failures.

87M+
USERS AFFECTED

$5B
FTC SETTLEMENT

Crisis
PUBLIC TRUST

Facebook Analysis

INCIDENT BREAKDOWN // CAMBRIDGE ANALYTICA

ATTACK TYPE

VECTOR

Data misuse by authorized third party

PRIMARY WEAKNESS

VULNERABILITY

Over-permissive Access

API allowed harvesting friends' data indiscriminately

Weak Governance

Failure to enforce third-party data policies

SECURITY INCIDENT REPORT

LASTPASS 2022

A developer compromise led to attackers accessing cloud storage and stealing millions of encrypted customer password vaults.

30M+
USERS AFFECTED

Vaults
ENCRYPTED DATA STOLEN

£3.1M
REGULATORY FINE (ICO)

LastPass Analysis

INCIDENT BREAKDOWN // PASSWORD MANAGER BREACH

ATTACK TYPE

VECTOR

Multi-stage breach via compromised developer endpoint

PRIMARY WEAKNESS

VULNERABILITY

Compromised Credentials

Valid keys stolen from employee laptop

Weak Endpoint Security

Unpatched media software on dev device

SECURITY INCIDENT REPORT

MOVEIT TRANSFER 2023

A massive zero-day supply chain attack exploiting a vulnerability in widely used file transfer software.

2,500+
ORGANIZATIONS AFFECTED

60M+
INDIVIDUALS IMPACTED

$10B+
ESTIMATED DAMAGES

MOVEit Analysis

INCIDENT BREAKDOWN // 2023

ATTACK TYPE

VECTOR

Zero-day SQL injection (CVE-2023-34362) exploited by CL0P ransomware gang

PRIMARY WEAKNESS

VULNERABILITY

Unpatched Zero-Day

Critical SQLi vulnerability in web-facing file transfer software

Supply Chain Risk

Single software flaw compromised 2,500+ downstream organizations

SECURITY INCIDENT REPORT

CHANGE HEALTHCARE 2024

A catastrophic ransomware attack disrupting the entire U.S. healthcare billing and prescription system.

100M+
INDIVIDUALS AFFECTED

Nationwide
OPERATIONS DISRUPTED

$872 M+
ESTIMATED DAMAGES

Change Healthcare Analysis

INCIDENT BREAKDOWN // 2024

ATTACK TYPE

VECTOR

Ransomware via compromised credentials (ALPHV/BlackCat)

PRIMARY WEAKNESS

VULNERABILITY

Lack of MFA

Critical portal accessed without 2FA

Segmentation Issues

Insufficient barriers to critical data

Major Data Breach Timeline

CHRONOLOGICAL PROGRESSION (2018-2024)

2018

FACEBOOK / CA

- 87 Million Users
- $5 Billion FTC Fine

2022

LASTPASS

- 30 Million Users
- Vaults Compromised

2023

MOVEIT / CL0P

- 2,500+ Organizations
- $10+ Billion Cost

2024

CHANGE HEALTHCARE

- 100+ Million People
- System Disruption

Regional Case Example: Vietnam

AIRLINE SECTOR INCIDENT

Vietnam Airlines

2022

TYPE OF INCIDENT

Unauthorized access & data leakage followed by service disruption

PRIMARY WEAKNESS (REPORTED)

- Insufficient protection of internal data systems
- Weak monitoring and incident detection capabilities

DATA & OPERATIONAL IMPACT

- Affected: Customer personal info & frequent-flyer data
- Public disclosure of customer data
- Temporary operational disruption

Exact financial cost not disclosed

Regional Case Example: Vietnam

SECURITIES SECTOR INCIDENT

VNDirect

2024

TYPE OF INCIDENT

Disruption and potential exposure of customer data systems

PRIMARY WEAKNESS (REPORTED)

- Inadequate protection of critical data services
- Insufficient resilience and monitoring capabilities

OPERATIONAL & FINANCIAL IMPACT

- Temporary service outage affecting trading operations
- Customer account access disruption
- Financial and reputational damage

Exact figures not publicly disclosed

Limitations of Case-Based Analysis

ACADEMIC SCOPE & METHODOLOGICAL BOUNDARIES

- Public incident reports remain inherently incomplete
- Specific technical details are often undisclosed
- Incidents involve multiple contributing factors
- Financial impact estimates vary significantly by source
- Cases emphasize detected failures, not successful defenses

ACADEMIC CAUTION

Analysis relies on publicly available information, not full forensic access.

Common Weaknesses Across Incidents

Weak access control

Over-permissive rights allow lateral movement

Poor credential management

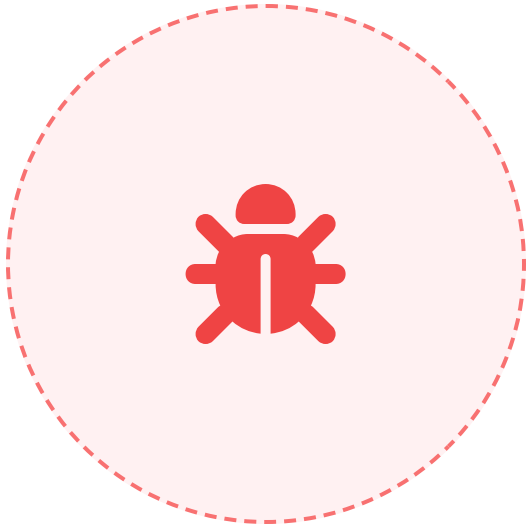
Static passwords and lack of MFA enabling takeovers

Misconfiguration

Default settings and open cloud storage buckets

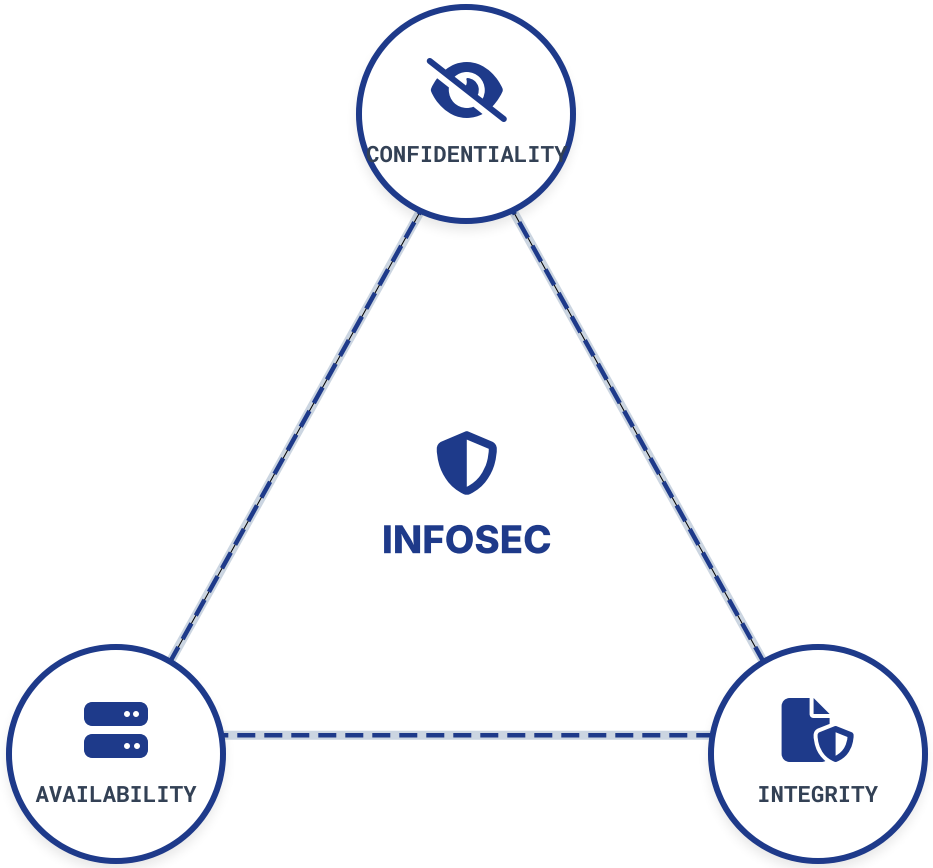
Lack of monitoring

Intrusions go undetected for months or years



Mapping Weaknesses to Security Goals

CIA TRIAD IMPACT ANALYSIS



IDENTIFIED WEAKNESS	SECURITY GOAL IMPACT (CIA)
Unauthorized Access	Confidentiality, Integrity
Data Misuse	Confidentiality, Integrity, Accountability
Misconfiguration	Confidentiality, Integrity
No Monitoring	Accountability, Integrity

Why Encryption Alone Is Not Enough

Access may still be granted

Legitimate users with valid credentials can still misuse decrypted data

Keys may be mismanaged

Poor key storage or hardcoded secrets render encryption ineffective

Policies may fail

Human error, misconfiguration, and social engineering bypass technical controls

Role of Access Control

Limits who can access data

Ensures only authorized identities can interact with assets

Reduces blast radius

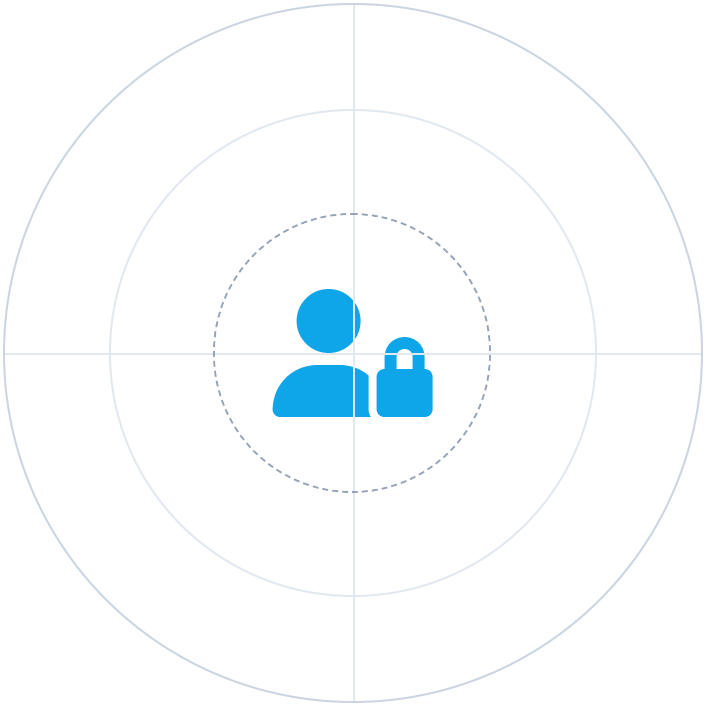
Minimizes potential damage if a single account is compromised

Supports accountability

Links specific actions to individual users for auditing

Over-privilege is a major risk

Many incidents stem from users having excessive permissions



Ethical and Legal Boundaries

Defensive learning only

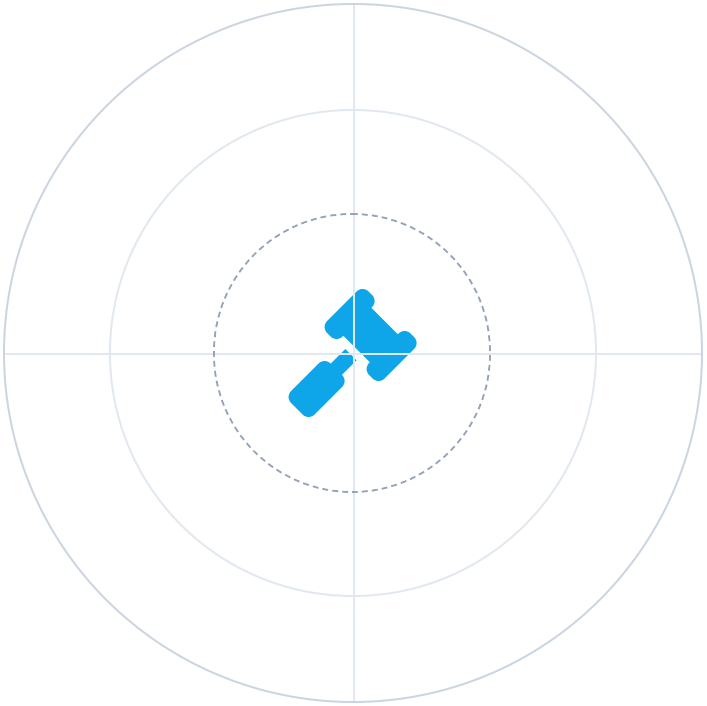
Focus on protection mechanisms and hardening, not active attacks

No exploit development

We analyze weaknesses to understand them, not to weaponize them

Responsible use required

Security knowledge carries significant professional and legal responsibility



Summary & Transition

Real incidents reveal weaknesses

Case studies show that simple failures like unpatched software and misconfiguration cause massive damage.

Weaknesses guide security design

Understanding how attacks happen allows us to build better defenses like access control and monitoring.

Next: Formal Threat Models

In Lecture 2, we will formalize these threats and learn how to model risks systematically.

Essential References & Further Reading

GOVERNMENT STANDARDS

NIST SP 1800-26 (CIA Triad)
nccoe.nist.gov/publication/1800-26/VolA/index.html

NIST SP 800-53 (Security Controls)
csrc.nist.gov/publications/detail/sp/800-53

REQUIRED TEXTBOOKS

Stallings: Cryptography and Network Security
8th Edition (2022) - Pearson

Anderson: Security Engineering
cl.cam.ac.uk/~rja14/book.html (3rd Ed, 2020)

CASE STUDY SOURCES

IBM 2024 Breach Roundup
ibm.com/think/insights/2024-roundup-top-data-breach

LastPass Security Incident
blog.lastpass.com/posts/notice-of-recent-security

Search: "MoveIT Vulnerability NCSC"

PROFESSIONAL STANDARDS

OWASP Top 10 (Logging Failures)
owasp.org/Top10/A09_2021-Security_Logging

CISA MOVEit Advisory
cisa.gov/news-events/cybersecurity-advisories/aa23-158a

INDUSTRY LEADERS

Fortinet CIA Triad Guide
fortinet.com/resources/cyberglossary/cia-triad

Splunk CIA Triad Explanation
splunk.com/en_us/blog/learn/cia-triad...

Practice Quiz — Self-Assessment

Part A: Multiple Choice

1. Which weakness was the primary enabler of the 2018 Facebook/Cambridge Analytica incident?
   - A) SQL Injection
   - B) Over-permissive API Access
   - C) Phishing
   - D) Ransomware

2. The 2022 LastPass breach demonstrated the risk of:
   - A) Public Cloud Buckets
   - B) Compromised Developer Endpoints
   - C) Zero-day in Transfer App
   - D) Lack of HTTPS

3. The MOVEit 2023 incident is best classified as a:
   - A) Insider Threat
   - B) Supply Chain / Zero-day Attack
   - C) DDoS Attack
   - D) Social Engineering

4. What critical control was missing in the Change Healthcare ransomware attack?
   - A) Firewalls
   - B) Multi-Factor Authentication (MFA)
   - C) Antivirus
   - D) Backups

5. Ransomware that encrypts files primarily violates which CIA principle?
   - A) Confidentiality
   - B) Integrity
   - C) Availability
   - D) Accountability

Part B: Short Answer Analysis

6. Explain how a supply chain attack (like MOVEit) differs from a direct breach of an organization's infrastructure.

7. Why is encryption alone insufficient for data security? Refer to the LastPass incident in your answer.

8. Map the "Lack of Monitoring" weakness to the CIA triad. Which principles are negatively affected and why?